

PIXELSTORE

Document de Spécifications Techniques

Infrastructure Cloud AWS - Architecture Sécurisée et Évolutive

Jimmy Barbier - Dorian Poncelet - Matthieu Broquard

Projet Final - Jedha Bootcamp Cybersécurité Fullstack

1. Introduction

Contexte

PixelStore est une PME parisienne de 35 employés spécialisée dans la vente en ligne de smartphones haut de gamme. Dans le cadre de sa transformation numérique, l'entreprise a décidé de migrer son infrastructure vers le cloud afin de répondre à des exigences croissantes de disponibilité, de sécurité et d'évolutivité.

Objectifs du projet

Ce projet a pour objectif de concevoir, déployer et sécuriser une infrastructure cloud complète sur AWS, entièrement automatisée via Terraform. L'infrastructure doit supporter une application e-commerce fonctionnelle, garantir la protection des données clients, assurer la continuité de service et respecter les meilleures pratiques en matière de cybersécurité.

Périmètre

L'infrastructure déployée couvre : réseau VPC Multi-AZ, application web Flask, base de données MySQL, load balancer, auto scaling, stockage S3, gestion des secrets, surveillance, audit et protection contre les menaces. L'ensemble représente 77 ressources AWS déployées en une seule commande.

Approche & équipe

L'ensemble de l'infrastructure est défini et déployé via Terraform (Infrastructure as Code), permettant un déploiement reproductible et automatisé. Un seul `terraform apply` suffit pour créer l'intégralité de l'infrastructure, uploader les assets sur S3, initialiser la base de données et lancer l'application Flask. Le projet a été réalisé **en équipe** par Jimmy Barbier, Dorian Poncelet et Matthieu Broquard, à contribution égale (architecture & IaC, application & test d'intrusion, gouvernance/risques/conformité).

2. Analyse des besoins

Besoins fonctionnels

L'application doit permettre de parcourir un catalogue de smartphones, consulter les fiches produits, gérer un panier et s'authentifier via un système de connexion et d'inscription sécurisé, accessible depuis n'importe quel navigateur.

Besoins techniques

- **Disponibilité** : le site doit rester accessible même en cas de panne d'une zone de disponibilité.
- **Évolutivité** : absorber les pics de trafic automatiquement sans intervention manuelle.
- **Sécurité** : données clients protégées en transit et au repos, accès strictement contrôlés.
- **Automatisation** : déploiement complet reproductible via une seule commande.

Contraintes

- **Budget** : services AWS dimensionnés pour une PME (t2.micro, db.t3.micro).
- **Équipe** : projet réalisé en équipe (Jimmy Barbier, Dorian Poncelet, Matthieu Broquard) dans le cadre du projet final Jedha Cybersécurité Fullstack.
- **Conformité RGPD** : données clients hébergées exclusivement en région AWS eu-west-3 (Paris), aucune répliquation hors UE.

3. Architecture réseau

Vue d'ensemble

L'infrastructure repose sur un VPC déployé en région eu-west-3 (Paris) en configuration Multi-AZ, réparti sur deux zones : eu-west-3a et eu-west-3b, garantissant la haute disponibilité.

Composants réseau

Composant	Configuration	Rôle
VPC	CIDR 10.0.0.0/16	Réseau privé isolé, DNS activé
Subnet public A	10.0.1.0/24 - eu-west-3a	Héberge ALB et EC2
Subnet public B	10.0.2.0/24 - eu-west-3b	Héberge ALB et EC2 (scale)
Subnet privé A	10.0.3.0/24 - eu-west-3a	Héberge RDS primaire
Subnet privé B	10.0.4.0/24 - eu-west-3b	Héberge RDS standby
Internet Gateway	1 par VPC	Point d'entrée depuis internet
NAT Gateway	IP publique	Accès sortant pour les subnets privés
Route Tables	Public (IGW) + Privé (NAT)	Routage selon le type de subnet

Flux réseau

Étape	Source	Destination	Port	Protection
1	Internet	Cloudflare (TLS) -> WAF	443/80	TLS Cloudflare + WAF 3 règles
2	WAF	ALB	80	SG ALB (restreint aux IP Cloudflare)
3	ALB	EC2	5000	SG EC2 (source SG ALB)
4	EC2	RDS	3306	SG RDS (source SG EC2)
5	EC2	Secrets Manager	443	IAM + HTTPS
6	EC2	S3	443	IAM + HTTPS

4. Choix technologiques

Cloud Provider : AWS

AWS a été choisi pour sa maturité, la richesse de ses services managés et sa région Paris (eu-west-3) garantissant la conformité RGPD.

Infrastructure as Code : Terraform

Terraform décrit l'ensemble de l'infrastructure sous forme de code versionnable. L'état est stocké dans un bucket S3 avec verrouillage DynamoDB. Les 17 modules permettent un déploiement complet en une commande.

Application : Python Flask

Flask expose 4 pages (catalogue, détail produit, panier, authentification) et communique avec la base via PyMySQL (requêtes paramétrées). Les mots de passe sont hachés avec bcrypt. En production, l'application est servie par **Gunicorn** (serveur WSGI), et non par le serveur de développement Werkzeug.

Base de données : MySQL sur RDS

Amazon RDS MySQL 8.0 en Multi-AZ assure la haute disponibilité. La gestion des credentials est déléguée à AWS Secrets Manager, éliminant tout secret en clair dans le code.

Stockage : Amazon S3

Le bucket S3 stocke les assets statiques et le package de déploiement, chiffré au repos (SSE-S3), accès public bloqué.

Load Balancer & TLS

L'Application Load Balancer répartit le trafic et effectue les health checks. Le chiffrement TLS est assuré en frontal par **Cloudflare** ; le security group de l'ALB n'accepte que les plages d'adresses IP de Cloudflare, empêchant tout accès direct en clair.

5. Infrastructure as Code (Terraform)

L'infrastructure est organisée en 17 modules indépendants et réutilisables, garantissant reproductibilité, traçabilité et automatisation.

Module	Rôle
vpc	Création du VPC et configuration DNS
subnets	Subnets publics et privés Multi-AZ
igw	Internet Gateway
nat	NAT Gateway et Elastic IP
route_tables	Tables de routage public et privé
security_groups	Security Groups en cascade ALB, EC2, RDS
nacl	NACLs publics et privés
secrets_manager	Credentials RDS + SECRET_KEY Flask (générée)
iam	Rôle EC2, policies least privilege, SSM
rds	MySQL Multi-AZ, binlogs/PITR + AWS Backup (snapshot 12 h)
alb	Load Balancer, Target Group, Health Check
ec2_asg	Launch Template et Auto Scaling Group
waf	Web Application Firewall (3 règles)
s3	Bucket média et upload assets automatique
cloudwatch	4 alarmes, dashboard et SNS
cloudtrail	Audit multi-région
guardduty	Détection de menaces

Backend sécurisé & déploiement

L'état Terraform est stocké dans un bucket S3 chiffré (AES256) avec verrouillage DynamoDB. Un seul `terraform apply` déploie les 77 ressources, uploades les assets, démarre les EC2, initialise la base et lance l'application via systemd - site opérationnel en 10 à 15 minutes.

6. Sécurité

Security Groups en cascade

Architecture en cascade stricte : le SG ALB n'accepte le trafic que depuis les IP Cloudflare ; le SG EC2 n'accepte le port 5000 que depuis le SG ALB ; le SG RDS n'accepte le port 3306 que depuis le SG EC2. Aucune ressource n'est directement exposée.

NACLs

Seconde couche de filtrage au niveau des subnets. Les subnets privés n'autorisent MySQL qu'en provenance du CIDR interne 10.0.0.0/16.

WAF

Règle	Type	Protection
AWSManagedRulesCommonRuleSet	Managed AWS	Attaques web communes (OWASP)
AWSManagedRulesSQLiRuleSet	Managed AWS	Injections SQL
RateLimitRule	Personnalisée	Blocage IP > 2000 req / 5 min (anti-DDoS)

TLS / chiffrement en transit

Le chiffrement TLS (HTTPS) est assuré par Cloudflare en frontal ; l'en-tête HSTS est activé. Le security group de l'ALB est restreint aux plages d'IP Cloudflare, ce qui empêche tout contournement du TLS par accès direct en HTTP. Les données au repos sont chiffrées en AES256 sur S3 et RDS.

Secrets & SECRET_KEY

Les credentials RDS et la SECRET_KEY Flask (64 caractères, générée par Terraform) sont stockés dans AWS Secrets Manager, jamais en clair. L'application les récupère via l'API AWS au démarrage et refuse de démarrer sans clé forte.

Durcissement applicatif

L'application applique : en-têtes de sécurité HTTP (CSP, HSTS, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy) ; cookies de session `Secure` + `SameSite=Lax` + `HttpOnly` ; politique de mot de passe serveur (>= 12 caractères, complexité) ; protection contre l'open redirect ; exécution sous utilisateur non privilégié. Ces mesures correspondent à la remédiation complète des constats du test d'intrusion interne (F1-F8 + F9).

GuardDuty & CloudTrail

GuardDuty analyse en continu CloudTrail, VPC Flow Logs et DNS ; les findings de sévérité moyenne/haute déclenchent une alerte SNS. CloudTrail assure l'audit multi-région, logs stockés dans un bucket S3 chiffré à accès public bloqué.

7. Gestion des identités et des accès

IAM - implémenté

Le rôle IAM des instances EC2 suit le moindre privilège : lecture du secret RDS uniquement, lecture/écriture du bucket média uniquement, accès sans clé SSH via SSM Session Manager. Aucun accès root, aucune clé stockée sur les instances.

AWS Managed Microsoft AD - recommandation

En production, l'intégration d'AWS Managed Microsoft AD permettrait une authentification centralisée (Admins / Développeurs / Employés / Comptabilité), une gestion simplifiée des arrivées/départs et la compatibilité AWS SSO.

8. Haute disponibilité

Multi-AZ

L'infrastructure est déployée sur deux zones (eu-west-3a/3b) ; en cas de panne d'une zone, le service continue.

Auto Scaling	Valeur	Description
Minimum	1 instance	Coût optimisé en période creuse
Maximum	2 instances	Une par zone de disponibilité
Déclencheur	CPU > 60%	Lancement automatique d'une 2e instance
Health check	Toutes les 30 s	Retrait du pool de toute instance défaillante

RDS Multi-AZ : réplique synchrone en eu-west-3b ; bascule automatique en 1 à 2 minutes en cas de panne de la primaire.

9. Reprise après sinistre

Mécanisme	Valeur
Snapshot complet	Toutes les 12 h via AWS Backup (00:00 et 12:00 UTC)
Binlogs / PITR	En continu (~15 min) - restauration à un instant T
Rétention	7 jours glissants

Les snapshots toutes les 12 h sont orchestrés par un plan **AWS Backup** dédié (coffre + plan + rôle IAM). En parallèle, les sauvegardes automatiques RDS (rétention 7 j) et le format de binlog **ROW** assurent la restauration à un instant T (PITR) à ~15 minutes près.

Indicateur	Valeur	Description
RPO	~15 minutes	Binlogs/PITR ~15 min + snapshot complet toutes les 12 h
RTO	~15 minutes	Remise en service via terraform apply + RDS

Terraform constitue lui-même un outil de reprise : l'intégralité de l'infrastructure est décrite en code versionné sur GitHub ; un `terraform apply` recrée les 77 ressources. **Axes** : RPO encore réduit via réplication RDS multi-région ; snapshots S3 cross-region ; warm standby pour réduire le RTO.

10. Surveillance et alerting

Alarme	Métrique	Seuil	Action
CPU EC2 élevé	CPUUtilization	> 80% / 4 min	Alerte SNS
Erreurs 5xx ALB	HTTPCode_Target_5XX	> 10 / min	Alerte SNS
Latence ALB	TargetResponseTime	> 2 s	Alerte SNS
Connexions RDS	DatabaseConnections	> 50	Alerte SNS

Les alarmes sont reliées à un topic SNS (notification email). GuardDuty et CloudTrail complètent la détection et l'audit. Les outils cloud natifs (CloudWatch, GuardDuty, CloudTrail) ont été privilégiés à une solution SIEM dédiée (ex. Wazuh) pour leur intégration native et leur facturation à l'usage.

11. Analyse des coûts

Service	Configuration	Coût mensuel
EC2	1x t2.micro	8 €
RDS	db.t3.micro Multi-AZ	55 €
ALB	1 load balancer	20 €
NAT Gateway	1 NAT + trafic	50 €
S3 / Secrets / WAF / GuardDuty / CloudTrail / CloudWatch	divers	~17 €
Total		~150 € / mois - 1 800 € / an

En On-Demand : 1 800 €/an ; avec un Savings Plan 1 an : moins de 900 €/an. Une infrastructure on-premise équivalente représente ~11 600 € d'investissement initial + ~8 820 €/an, soit un coût année 1 de ~20 420 €. **Le cloud AWS représente une économie de plus de 18 000 € la première année**, sans investissement matériel et avec la haute disponibilité incluse. TLS assuré gratuitement par Cloudflare (plan Free).

12. Analyse des risques

Risque	Prob.	Impact	Mitigation
Panne d'une zone	Faible	Élevé	Multi-AZ, basculement automatique
Injection SQL	Moyenne	Élevé	Requêtes paramétrées + WAF SQLi
Attaque DDoS	Moyenne	Élevé	WAF RateLimit + Cloudflare
Interception réseau	Faible	Élevé	TLS via Cloudflare (HTTPS), HSTS
Compromission credentials	Faible	Élevé	Secrets Manager, aucun secret en clair
Accès non autorisé AWS	Faible	Élevé	IAM least privilege
Perte de données	Faible	Élevé	Snapshots RDS, rétention 7 j
Non-conformité RGPD	Faible	Élevé	Déploiement exclusif eu-west-3 (Paris)

Risques résiduels (axes production)

- Pas d'authentification multi-facteurs (MFA) sur le compte AWS.
- Chiffrement Cloudflare -> ALB encore en clair (passage en Full Strict avec certificat d'origine recommandé).
- Pas de test de pénétration régulier automatisé.
- AWS Managed Microsoft AD non implémenté - gestion des identités limitée à IAM.
- Gouvernance organisationnelle à formaliser (réponse à incident, reprise, registre RGPD).

13. Conclusion

Ce projet a permis de concevoir, déployer et sécuriser une infrastructure cloud complète pour PixelStore. Un seul `terraform apply` déploie 77 ressources AWS et rend le site fonctionnel en moins de 15 minutes. Les vulnérabilités identifiées lors du test d'intrusion interne ont toutes été remédiées dans le code.

Points forts

- Architecture Multi-AZ garantissant la continuité de service.
- Sécurité en profondeur : Cloudflare/TLS, WAF, Security Groups en cascade, NACLs, Secrets Manager, GuardDuty, CloudTrail + durcissement applicatif.
- Automatisation complète et reproductible via Terraform, versionnée sur GitHub.
- Conformité RGPD (région Paris) et coût maîtrisé (~150 €/mois).

Axes d'amélioration

- Chiffrement de bout en bout Cloudflare -> ALB (Full Strict).
- Activation du MFA sur le compte AWS.
- Intégration d'AWS Managed Microsoft AD.
- Optimisation des coûts via Savings Plans.
- Pipeline CI/CD avec scan IaC (Checkov, tfsec).

Document réalisé en équipe - Jimmy Barbier - Dorian Poncelet - Matthieu Broquard - Jedha Bootcamp Cybersécurité Fullstack - Juin 2026